Política de Segurança da Informação e Privacidade (LGPD)

Campo	Conteúdo
Código	BO-POL-05
Versão	1.0
Data	05/11/2026
Aprovação	Raphael Mendonça Barros Silva, Administrador
Responsável	Michael Mendonça Barros Silva, Diretor de Compliance e PLD/FTP e Encarregado pelo Tratamento de Dados Pessoais
Empresa	BLACK OPS LTDA, CNPJ 58.557.156/0001-58
Documentos relacionados	BO-GOV-01, BO-POL-01, BO-POL-02, BO-POL-03, BO-POL-04, BO-POL-06

1. Objetivo

1.1. Definir as regras de proteção da informação da BLACK OPS LTDA (confidencialidade, integridade e disponibilidade) e de tratamento de dados pessoais conforme a Lei 13.709/2018 (LGPD).

1.2. Esta política distingue, em cada controle técnico, o que **já está implementado** no software POKER (com a evidência correspondente), o que é **regra vigente a verificar e registrar**, o que está **em implementação** (código escrito, ainda sem evidência de aplicação e teste) e o que será **implementado antes da operação com dinheiro real**. O quadro consolidado está no Anexo A.

2. Abrangência

2.1. Aplica-se a toda informação da empresa, em qualquer meio, aos sistemas e contas que a armazenam, aos dois sócios, a colaboradores ou prestadores futuros e aos fornecedores que tratam dados em nome da empresa.

2.2. Sistemas abrangidos: plataforma POKER (aplicação Next.js hospedada na Vercel, banco de dados e autenticação no Supabase, código no GitHub em repositório privado); conta de pagamento na Trio; plataforma de infoprodutos (vendas de cursos); contas de Instagram, WhatsApp e e-mail usadas no atendimento; computadores e celulares dos sócios.

3. Definições

- **Dado pessoal**, **dado pessoal sensível**, **titular**, **controlador**, **operador**, **encarregado**, **tratamento** e **ANPD**: conforme a LGPD.
- **Conta administrativa**: conta com poder de alterar sistema, dados, chaves, dinheiro ou acessos.
- **Segredo**: chave de API, token, senha, semente TOTP ou chave de criptografia.
- `service_role`: chave do Supabase que ignora as regras de RLS; só pode existir no servidor.
- **RLS (Row Level Security)**: regras do banco que definem, linha a linha, o que cada usuário pode ler ou gravar.
- **Seed**: valor aleatório de 32 bytes que determina o embaralhamento de uma mão de poker.

4. Classificação da informação

Classe	Conteúdo	Quem acessa	Regras
Pública	Conteúdo do Instagram, páginas de venda, regras das mesas, histórico de mãos encerradas exibido na plataforma	Qualquer pessoa	Revisão antes de publicar

Classe	Conteúdo	Quem acessa	Regras
Interna	Planos, métricas de negócio, documentação técnica, código-fonte	Sócios e prestadores autorizados	Repositórios e pastas privados
Confidencial	Dados pessoais de clientes e jogadores (e-mail, nome, CPF, histórico financeiro), relatórios de vendas, extratos, contratos	Sócios, na medida da função; operadores contratados	Acesso nominal, MFA, mínimo necessário; nunca em grupos ou canais abertos
Restrita	Segredos; seeds das mãos (tabela `hand_secrets`); dados de KYC; análises e comunicações de PLD/FTP ao COAF; registros de incidentes	Somente o Diretor e, quando necessário, o Administrador	Nunca em código de cliente, repositório, e-mail ou mensagem; comunicações ao COAF sob sigilo (Lei 9.613/1998)

4.1. Na dúvida, aplica-se a classe mais alta. Quem cria a informação a classifica.

5. Controle de acesso

5.1. **Menor privilégio**: cada pessoa e cada sistema recebe só o acesso necessário à sua função. Acesso é nominal; não há contas compartilhadas, exceto as contas institucionais que, por natureza, são únicas (ex.: perfil do Instagram), cujo acesso é registrado.

5.2. **MFA obrigatório** em todas as contas administrativas: Supabase (organização e projeto `poker`), Vercel (time e projeto `poker`), GitHub (conta proprietária do repositório `poker`), Trio (internet banking e painel), e-mail michael@mikhaeu.com, plataforma de infoprodutos, Meta (Instagram e WhatsApp Business). Preferência por aplicativo autenticador ou chave física; SMS só onde não houver alternativa. Situação: regra vigente. O Diretor verifica cada conta e registra a evidência (captura da tela de segurança de cada serviço, com data) no registro de acessos antes do envio desta política à Trio; conta sem MFA é ativada no mesmo dia ou bloqueada (BO-POL-04, KRI).

5.3. **Acesso dos usuários finais à plataforma POKER** (implementado):

- a) autenticação pelo Supabase Auth com código de uso único enviado por e-mail (OTP); a aplicação valida a sessão em cada chamada de API;
- b) RLS ativo em todas as tabelas do esquema público (`profiles`, `ledger`, `tables`, `seats`, `hands`, `actions`, `hand_secrets`, `schema_migrations`);
- c) clientes (papéis `anon` e `authenticated`) não têm permissão de inserir, alterar ou apagar em nenhuma tabela; a única exceção é o próprio apelido (`profiles.nick`), restrito ao dono da linha;
- d) cada usuário só lê as próprias linhas do ledger; o estado completo da mesa (`tables.state`, que contém as cartas fechadas de todos) não é legível por cliente, que vê apenas a visão pública sem cartas; mãos e ações só ficam visíveis depois de encerradas;
- e) as funções que movem saldo (`buyin`, `credit_test`, `leave_table`, `settle_hand`, `create_table_limited`) só podem ser executadas pelo servidor;
- f) no canal privado em tempo real de cada mesa, só as mensagens do servidor chegam aos jogadores; mensagens enviadas por clientes não são entregues aos demais.

Evidência: `supabase/migrations/0001_init.sql`, `supabase/migrations/0002_security_fixes.sql` e testes em `run/F1_evidence.md` (ex.: leitura anônima de `hand_secrets` negada com erro 42501; chamada anônima de `settle_hand` e `buyin` negada com 401).

5.4. **Concessão e retirada**: acesso administrativo é concedido pelo Administrador, executado e registrado pelo Diretor (pessoa, sistema, nível, data, motivo). Na saída de pessoa ou fim de contrato, o acesso é retirado no mesmo dia e os segredos que ela conhecia são rotacionados.

5.5. **Revisão trimestral**: em janeiro, abril, julho e outubro, o Diretor lista os membros e tokens de cada sistema do item 5.2, remove o que não for necessário e registra o resultado em ata do Comitê. A primeira revisão ocorre até 31/01/2027.

5.6. **Segregação no poker**: sócios e qualquer pessoa com acesso administrativo ao servidor ou ao banco não podem jogar em mesas com dinheiro real (BO-GOV-01).

6. Gestão de segredos

6.1. Segredos ficam somente em variáveis de ambiente do servidor (Vercel) e em arquivo `.env` local nos computadores dos sócios. Nunca no código, no repositório, no navegador do cliente, em mensagens ou em documentos.

6.2. Situação (implementado): a chave `service_role` é lida apenas em módulos de servidor (`app/lib/server/`); o código executado no navegador recebe só a URL pública do Supabase e a chave pública `anon`, cujo poder é limitado pelas regras de RLS do item 5.3. Os arquivos `.env` e `.env.*` estão excluídos do controle de versão (`.gitignore`).

6.3. **Rotação**: segredos são rotacionados (a) imediatamente em caso de suspeita de exposição, perda de dispositivo ou saída de pessoa com acesso; (b) no mínimo a cada 12 meses. Tokens de API são criados com o menor escopo e o menor prazo de validade que o serviço permitir. Situação: regra vigente; a primeira rotação programada e o procedimento escrito de rotação da `service_role` sem interrupção do serviço são a implementar antes da operação com dinheiro real.

6.4. Ferramentas de automação de desenvolvimento executadas no computador do Diretor usam as credenciais do `.env` local e seguem as mesmas regras: nenhuma credencial é copiada para fora da máquina, enviada em mensagem ou gravada em repositório.

7. Criptografia

7.1. **Em trânsito**: toda comunicação com a aplicação e com as APIs do Supabase, da Vercel e da Trio é feita por HTTPS (TLS) fornecido pelos provedores. Não há endpoint da aplicação servido sem TLS.

7.2. **Em repouso**: os dados ficam no banco gerenciado do Supabase (projeto na região sa-east-1, São Paulo) e nos sistemas dos demais provedores, com a criptografia em repouso oferecida por eles conforme a documentação de segurança de cada um. A empresa não mantém servidor próprio.

7.3. **Hash de compromisso**: o hash SHA-256 da seed de cada mão é gravado e publicado (`hands.seed_hash`) e a seed fica em tabela restrita (item 9.6).

7.4. Em implementação (migração `supabase/migrations/0003_compliance.sql`, ainda sem evidência de aplicação): o CPF não é gravado em claro; o banco guarda apenas o HMAC-SHA256 do CPF, calculado com chave secreta (pepper) que existe só em variável de ambiente do servidor, e os 4 últimos dígitos para conferência humana. O controle passa a "implementado" quando a migração estiver aplicada e testada, com evidência em `run/C1_evidence.md`; é pré-requisito para a operação com dinheiro real.

8. Segurança de aplicação

8.1. **Revisão adversarial antes de cada release** que altere dinheiro, autenticação, permissões ou cartas: revisão independente do código com foco em ataque (criação de fichas, vazamento de cartas, saldo negativo, ação fora de turno, condição de corrida). Os achados são corrigidos antes da publicação e a correção é provada por teste. Situação: realizada em 05/11/2026 sobre a versão 1 do POKER, com 8 achados (1 crítico, 3 altos, 1 médio-alto, 1 médio, 2 baixos), todos corrigidos e verificados (`run/F1_evidence.md`).

8.2. **Testes de exploit automatizados** (`tools/exploit_tests.py`): reproduzem os ataques conhecidos contra a API e o banco (créditos e buy-ins paralelos, débito acima do saldo, ação com o assento de outro jogador, leitura de seed, chamada de funções internas por usuário anônimo, saída no meio da mão para criar fichas) e verificam o invariante global do ledger. Resultado em 05/11/2026: aprovado. Junto, `tools/smoke_api.py` joga mãos completas por HTTP. Regra: os dois rodam antes de cada release; release

só com resultado aprovado.

8.3. **Integridade do saldo** (implementado):

- a) toda movimentação de saldo é uma linha nova no ledger, em centavos inteiros; não existe campo de saldo editável, o saldo é a soma das linhas;
- b) cada caminho que move dinheiro é uma única transação no banco, com trava por usuário e por mesa, de modo que operações simultâneas não duplicam crédito nem débito;
- c) o gatilho `ledger_guard` recusa qualquer débito que deixe um usuário (exceto a conta da casa) com saldo negativo, inclusive quando a gravação vem do servidor;
- d) a liquidação de uma mão é idempotente: repetir a chamada não gera novas linhas.

8.4. **Ledger append-only**: hoje nenhum cliente consegue alterar ou apagar linhas (permissões revogadas) e o código do servidor só insere. A implementar antes da operação com dinheiro real: gatilho no banco que recuse UPDATE e DELETE no ledger, nas mãos e nas ações também para o servidor, de modo que correções só ocorram por lançamento de ajuste (`adjust`) com justificativa e dupla aprovação (BO-GOV-01).

8.5. **Limites contra abuso** (implementado): no máximo 5 créditos de fichas de teste por usuário por dia; no máximo 3 mesas criadas por usuário por dia; parâmetros de mesa restritos a uma lista permitida (blinds, lugares, rake de 5%, buy-in entre 40 e 200 big blinds).

8.6. **Geração de números aleatórios** (implementado): a seed de cada mão tem 32 bytes gerados pelo gerador criptográfico do Node.js (`crypto.randomBytes`); o baralho é embaralhado por Fisher-Yates a partir dessa seed, o que torna cada mão reproduzível para auditoria. A seed nunca é enviada a cliente; fica na tabela `hand_secrets` (sem acesso para clientes), e o seu hash SHA-256 é público desde o início da mão. Com a seed, a empresa ou um auditor reconstrói o baralho exato e confere que o hash publicado corresponde. A implementar antes da operação com dinheiro real: avaliação do gerador e do embaralhamento por laboratório ou auditor independente.

8.7. Controle de versão: todo o código está no GitHub em repositório privado; mudanças no banco são feitas apenas por arquivos de migração versionados e registrados na tabela `schema_migrations`.

8.8. A implementar antes da operação com dinheiro real: cabeçalhos de segurança HTTP (política de conteúdo, HSTS), limite de requisições por origem nas APIs públicas e alerta automático de falha do invariante do ledger.

9. Logs e trilha de auditoria

9.1. Registros existentes (implementado):

- a) ledger: cada movimento com usuário, tipo, valor, mesa, mão, metadados e data/hora;
- b) mãos: início, fim, board, pote, rake, resultado, hash da seed e o log completo das ações em ordem (`hands.log`), suficiente para reproduzir a mão;
- c) ações: cada ação de cada jogador com rua, valor e data/hora (`actions`);
- d) logs de autenticação do Supabase e logs de execução da Vercel, com a retenção do plano contratado de cada provedor;
- e) histórico de mudanças do código (Git) e das migrações do banco.

9.2. Em implementação (migração `0003_compliance.sql`, ainda sem evidência de aplicação): tabela `audit_log` append-only, em que um gatilho recusa UPDATE, DELETE e TRUNCATE para qualquer papel, sem acesso de clientes, alimentada por gatilhos de auditoria nas tabelas de KYC, alertas de PLD e destinos de saque. Passa a "implementado" com evidência em `run/C1_evidence.md`. A implementar antes da operação com dinheiro real: registro em `audit_log` de todas as ações administrativas (bloqueio de conta, aprovação de saque, ajuste, mudança de limite), retenção de 10 anos e exportação periódica dos logs dos provedores para guarda própria.

9.3. Logs não contêm segredos. Logs com dados pessoais são Confidenciais.

10. Backup e recuperação

10.1. O banco do POKER é coberto pelos backups automáticos do Supabase conforme o plano contratado; o código, pelo repositório no GitHub e pela cópia local.

10.2. A implementar antes da operação com dinheiro real: (a) recuperação a ponto no tempo (PITR) no banco de produção; (b) exportação lógica diária do banco para armazenamento separado, com acesso restrito; (c) teste de restauração semestral, registrado em ata, medindo o tempo de recuperação. Objetivo: perda máxima de dados de 5 minutos para o ledger e restauração em até 24 horas.

11. Resposta a incidentes de segurança e de dados pessoais

11.1. Segue a gestão de incidentes do BO-POL-04 (seção 10), com estes passos específicos:

- a) **conter**: revogar sessões e tokens, rotacionar segredos, retirar a aplicação do ar ou suspender mesas se necessário;
- b) **preservar evidências**: logs, capturas e linha do tempo, antes de qualquer correção destrutiva;
- c) **avaliar**: dados e titulares afetados, categoria dos dados, risco ou dano relevante aos titulares;
- d) **comunicar**: quando o incidente puder acarretar risco ou dano relevante aos titulares, o Encarregado comunica a ANPD e os titulares afetados (LGPD, art. 48), no prazo de 3 dias úteis do conhecimento do incidente previsto no regulamento da ANPD sobre comunicação de incidentes (Resolução CD/ANPD nº 15/2024), com as informações exigidas pela norma; a Trio é avisada sem demora quando o incidente afetar a conta, as transações ou dados compartilhados com ela;
- e) **corrigir e verificar** com teste, e **registrar** no registro de incidentes, mesmo quando não houver comunicação, com a justificativa.

11.2. A decisão de comunicar ou não é do Encarregado, informada ao Administrador e registrada em ata.

12. Privacidade e LGPD

12.1. **Encarregado (DPO)**: Michael Mendonça Barros Silva, contato michael@mikhaeu.com (LGPD, art. 41). A identidade e o contato do Encarregado serão publicados no site da empresa e na plataforma POKER em até 30 dias desta versão, junto com o aviso de privacidade.

12.2. **Inventário de tratamento**:

Atividade	Dados	Finalidade	Base legal (LGPD)
Venda de cursos	Nome, e-mail, CPF, dados de pagamento (coletados pela plataforma de infoprodutos)	Entregar o curso, emitir nota, atender	Execução de contrato; obrigação legal
Atendimento	Nome, contato, conteúdo da mensagem	Responder e resolver	Execução de contrato; legítimo interesse
POKER (fichas de teste, hoje)	E-mail, apelido, histórico de jogo, registros técnicos	Prestar o serviço, segurança da plataforma	Execução de contrato; legítimo interesse (segurança e prevenção a fraude)
POKER com dinheiro real (futuro)	Nome, CPF, data de nascimento, chave Pix e conta, CPF do pagador, resultado de screening	KYC, prevenção a fraude, PLD/FTP, bloqueio de menores	Obrigação legal ou regulatória; execução de contrato; legítimo interesse
Afiliados	Nome, CPF ou CNPJ, chave Pix, desempenho	Pagar comissão, PLD/FTP	Execução de contrato; obrigação legal

12.3. Não é tratado dado de criança ou adolescente: a plataforma é proibida a menores de 18 anos, e cadastro identificado como de menor é bloqueado e excluído, salvo o mínimo necessário para impedir novo cadastro.

12.4. **Minimização e retenção**: coleta-se só o necessário para a finalidade. Dados de PLD/FTP e KYC são guardados por no mínimo 10 anos após o fim do relacionamento; os demais, pelo tempo da finalidade e dos

prazos legais aplicáveis; depois são eliminados ou anonimizados.

12.5. **Direitos dos titulares** (LGPD, art. 18): confirmação e acesso, correção, anonimização, bloqueio ou eliminação de dados desnecessários ou excessivos, portabilidade, informação sobre compartilhamento, revogação do consentimento quando esta for a base, e revisão de decisão automatizada. Pedidos pelo e-mail do Encarregado ou pelos canais do BO-POL-06. Confirmação de existência ou acesso em formato simplificado de imediato; declaração completa em até 15 dias (LGPD, art. 19). A eliminação não alcança dados que a empresa deve conservar para cumprir obrigação legal ou regulatória (LGPD, art. 16), o que é informado ao titular. Antes de atender, confirma-se a identidade do solicitante. Os pedidos e respostas são registrados.

12.6. **Compartilhamento**: dados pessoais só são compartilhados com os fornecedores da seção 13, com autoridades quando exigido por lei e com a Trio na medida das operações de pagamento. Comunicações ao COAF seguem o sigilo legal e não são informadas ao titular.

12.7. **Transferência internacional**: Supabase, Vercel e GitHub são empresas sediadas no exterior; mesmo com o banco na região de São Paulo, pode haver tratamento fora do Brasil por esses provedores. A empresa usa os termos de proteção de dados oferecidos por eles e avalia o enquadramento da transferência (LGPD, art. 33) na due diligence anual.

13. Fornecedores

Fornecedor	Serviço	Dados tratados	Controles exigidos
Supabase	Banco de dados, autenticação, tempo real (projeto `poker`, região sa-east-1)	Todos os dados do POKER	MFA na conta; termos de proteção de dados; backups; acesso restrito à organização
Vercel	Hospedagem da aplicação e das APIs	Dados em trânsito, logs de execução	MFA no time; segredos em variáveis de ambiente; deploy só pelos sócios
GitHub	Repositório privado do código	Código; nenhum dado de cliente e nenhum segredo	MFA; repositório privado; `.env` fora do controle de versão
Trio	Conta de pagamento, Pix, lote, cartão corporativo	Dados de pagadores e recebedores, extratos	MFA; acesso nominal; conciliação; contrato
Plataforma de infoprodutos	Vendas de cursos	Dados de compradores	MFA; acesso nominal
Meta (Instagram, WhatsApp)	Canais de atendimento	Mensagens de clientes	MFA; dados de cliente não ficam em conversas além do necessário
Fornecedor de KYC	Validação de CPF e identidade	Dados de cadastro	A contratar antes da operação com dinheiro real, com contrato de operador

13.1. Antes de contratar fornecedor que trate dados Confidenciais ou Restritos, o Diretor verifica a documentação de segurança e privacidade, o local de tratamento e os termos de proteção de dados, e registra a análise. Revisão anual de todos.

14. Dispositivos e senhas

14.1. Computadores e celulares usados no trabalho: sistema operacional e navegador atualizados; bloqueio de tela com senha, PIN ou biometria; disco criptografado quando o sistema oferecer (BitLocker, FileVault ou criptografia nativa do celular); sem compartilhamento com terceiros.

14.2. Senhas: únicas por serviço, guardadas em gerenciador de senhas, com no mínimo 12 caracteres; nunca reutilizadas nem enviadas por mensagem. Senha de conta administrativa vazada ou suspeita é trocada de imediato.

14.3. Perda ou roubo de dispositivo é comunicado ao Diretor no mesmo dia e segue o plano de continuidade do BO-POL-04.

14.4. Não se instalam aplicativos de origem desconhecida nos dispositivos com acesso administrativo; links e anexos recebidos por mensagem não são abertos em sessão com conta administrativa sem verificação.

15. Papéis

15.1. **Administrador**: aprova esta política, aprova concessão de acessos administrativos e decide, com o Encarregado, sobre comunicações de incidentes.

15.2. **Diretor e Encarregado (Michael)**: executa os controles, mantém os registros de acessos, fornecedores, incidentes e pedidos de titulares, conduz a revisão adversarial e os testes antes de release, atende titulares e a ANPD.

15.3. **Comitê de Compliance**: acompanha os indicadores e o Anexo A mensalmente.

16. Registros e guarda

16.1. Registros mantidos pelo Diretor: registro de acessos e revisões trimestrais, evidências de MFA, registro de fornecedores, registro de incidentes, registro de pedidos de titulares, evidências de revisão adversarial e de testes por release.

16.2. Guarda mínima de 5 anos; registros ligados a PLD/FTP, 10 anos.

17. Treinamento

17.1. Leitura desta política pelos dois sócios na aprovação. Treinamento anual de segurança e privacidade conduzido pelo Diretor (phishing, senhas, incidentes, direitos dos titulares), com presença registrada em ata. Prestador com acesso a sistemas lê esta política antes de receber acesso.

18. Revisão

18.1. Revisão anual, até 05/11/2027, ou antes em caso de incidente crítico, mudança de fornecedor crítico, início da operação com dinheiro real ou mudança normativa. O Anexo A é atualizado a cada controle implementado.

19. Sanções internas

19.1. O descumprimento desta política é tratado pelo Comitê conforme o BO-GOV-01: orientação formal, retirada de acessos, afastamento da função e, para prestadores, rescisão do contrato, sem prejuízo das consequências legais.

20. Vigência

20.1. Esta política entra em vigor na data da sua aprovação pela Reunião de Sócios de 05/11/2026 (ATA-01).

Anexo A — Situação dos controles em 05/11/2026

Controle	Situação	Evidência ou prazo
RLS em todas as tabelas; clientes sem escrita; estado da mesa e seeds inacessíveis a clientes	Implementado	Migrações 0001 e 0002; `run/F1_evidence.md`
Funções de dinheiro transacionais, só servidor; `ledger_guard` (saldo nunca negativo)	Implementado	Migração 0002; testes de exploit aprovados
Chave `service_role` só no servidor; `.env` fora do Git	Implementado	`app/lib/server/`; `.gitignore`

Controle	Situação	Evidência ou prazo
RNG criptográfico; seed restrita; hash SHA-256 público; mão reproduzível	Implementado	`packages/engine`; migração 0002
Revisão adversarial antes de release; testes de exploit e smoke	Implementado (1ª revisão em 05/11/2026)	`run/F1_evidence.md`, `tools/exploit_tests.py`, `tools/smoke_api.py`
Limites contra abuso (créditos, mesas, parâmetros)	Implementado	Migração 0002; testes de exploit
Histórico de mãos, ações e ledger com data/hora	Implementado	Tabelas `hands`, `actions`, `ledger`
TLS em trânsito; criptografia em repouso dos provedores	Implementado pelos provedores	Documentação dos provedores
MFA em todas as contas administrativas do item 5.2	Regra vigente; verificação a registrar	Evidência por conta antes do envio desta política à Trio
Revisão trimestral de acessos	Regra vigente	1ª até 31/01/2027
Publicação do Encarregado e aviso de privacidade	A implementar	Até 30 dias desta versão
Rotação programada de segredos e procedimento de rotação da `service_role`	A implementar antes da operação com dinheiro real	—
Gatilho que recusa UPDATE/DELETE em ledger, mãos e ações	A implementar antes da operação com dinheiro real	—
Trilha de auditoria append-only (`audit_log`)	Em implementação (migração 0003)	Evidência em `run/C1_evidence.md`; cobertura de todas as ações administrativas antes da operação com dinheiro real
PITR, exportação diária e teste de restauração	A implementar antes da operação com dinheiro real	—
CPF só como HMAC-SHA256 com chave fora do banco	Em implementação (migração 0003)	Evidência em `run/C1_evidence.md`; pré-requisito para dinheiro real
Avaliação independente do RNG	A implementar antes da operação com dinheiro real	—
Cabeçalhos de segurança, limite de requisições, alerta do invariante	A implementar antes da operação com dinheiro real	—

Aprovação — Florianópolis/SC, 05/11/2026.

Raphael Mendonça Barros Silva
Administrador · aprovação

Michael Mendonça Barros Silva
Diretor de Compliance e PLD/FTP · responsável